discovered—while also helping to ensure that individuals are not unduly denied timely access to information about the unauthorized access to or use of their sensitive customer information.

With respect to commenters who recommended that other Federal agencies, State and local law enforcement agencies, and foreign law enforcement authorities also be permitted to trigger a delay or suggested that the perceived limited nature of this delay would cause conflict with state authorities, the rule does not preclude any such entity from requesting that the Attorney General determine that the disclosure poses a substantial risk to national security or public safety and communicate that determination to the Commission. Designating a single law enforcement agency as the point of contact for both the covered institution and the Commission on such delays is critical to ensuring that the rule is administrable. Some commenters stated concerns about the feasibility and process of reaching out to the Attorney General to request a delay, urging the Commission to expand the delay to apply to requests made by other law enforcement agencies in addition to the Attorney General. The FBI, in coordination with the Department of Justice, has since provided guidance on how firms can request disclosure delays for national security or public safety reasons in connection with the Public Company Cybersecurity Rules.[195] To the extent needed, further guidance may be issued on how other law enforcement agencies may contact the Department of Justice to request a delay.

The final amendments also will expand the amount of time that a covered institution can delay notice under this provision. However, we are not persuaded, as some commenters suggested, that the rules should not incorporate a timing component at all because such an approach would diminish the goal of providing customers (regardless of state residency) with

---

[195] *See* FBI Guidance to Victims of Cyber Incidents on SEC Reporting Requirements, available at: https://www.fbi.gov/investigate/cyber/fbi-guidance-to-victims-of-cyber-incidents-on-sec-reporting-requirements.

timely and consistent notification of data breaches so that they may take remedial action. This includes permitting, in extraordinary circumstances, a delay for a final additional period of up to 60 days—following two previous 30-day extensions—if the Attorney General determines that disclosure continues to pose a substantial risk to national security and notifies the Commission of such determination in writing. We are providing for this additional delay period in the final amendments, beyond what was originally proposed, and in addition to the two 30-day delays that may precede it, in recognition that, in extraordinary circumstances, national security concerns may justify additional delay beyond that warranted by public safety concerns, due to the relatively more critical nature of national security concerns.[196] Beyond the final 60-day delay, if the Attorney General indicates to the Commission in writing that further delay is necessary, the covered institution can request an additional delay that the Commission may grant through exemptive order or other action. These modifications acknowledge that additional time beyond that proposed may be necessary, as called for by commenters, while balancing national security and public safety concerns against affected individuals' informational needs.

**e. Notice Contents and Format**

The final amendments, consistent with the proposal, require that notices include key information with details about the incident, the breached data, and how affected individuals can respond to the breach to protect themselves. This requirement is designed to help ensure that covered institutions provide basic information to affected individuals that will help them avoid or mitigate substantial harm or inconvenience. In a modification from the proposal, however, the

[196] Under the proposal, in contrast, the covered institution could delay a notice if the Attorney General informed the covered institution, in writing, that the notice poses a substantial risk to national security. The proposal provided that the covered institution could delay such a notice for a time period specified by the Attorney General, but not for longer than 15 days, plus an additional period of up to 15 days if the Attorney General determines that the notice continues to pose a substantial risk to national security.

final amendments will not require the notice to "[d]escribe what has been done to protect the sensitive customer information from further unauthorized access or use."

Some of the information required by the final amendment, including information regarding a description of the incident, and the type of sensitive customer information accessed or used without authorization, will provide affected individuals with basic information to help them understand the scope of the incident and its potential ramifications. As proposed, the final amendments will require covered institutions to include contact information sufficient to permit an affected individual to contact the covered institution to inquire about the incident, including a telephone number (which should be a toll-free number if available), an email address or equivalent method or means, a postal address, and the name of a specific office to contact for further information and assistance, so that affected individuals can easily seek additional information from the covered institution. All of this information may help affected individuals assess the risk posed by the incident and whether to take additional measures to protect against harm from unauthorized access or use of their information.

Similarly, as proposed, the final amendments will require information regarding the date of the incident, the estimated date of the incident, or the date range within which the incident occurred, if such information is reasonably possible to determine at the time the notice is provided. This requirement reflects the reality that a covered institution may have difficulty determining a precise date range for certain incidents because it may only discover an incident well after an initial time of access.[197]

In addition, as proposed, the final amendments will require that covered institutions include certain information to assist affected individuals in evaluating how they should respond

[197] *See* Proposing Release at n.142.

to the incident. Specifically, if the affected individual has an account with the covered institution, the final amendments will require the notice to recommend that the customer review account statements and immediately report any suspicious activity to the covered institution. The final amendments will also require the notice to explain what a fraud alert is and how an affected individual may place a fraud alert in credit reports. Further, the final amendments will require that the notice recommend that the affected individual periodically obtain credit reports from each nationwide credit reporting company and that the individual have information relating to fraudulent transactions deleted. The notice must also explain how a credit report can be obtained free of charge. Lastly, the final amendments require that notices include information regarding FTC and usa.gov guidance on steps an affected individual can take to protect against identity theft, a statement encouraging the individual to report any incidents of identity theft to the FTC, and the FTC's website address. These specific requirements are designed to give affected individuals resources and additional information to help them evaluate how they should respond to the incident.

As proposed, under the final rules covered institutions will be required to provide the information specified in the final amendments in each required notice. While we recognize that relevant information may vary based on the facts and circumstances of the incident, customers will benefit from the same minimum set of basic information in all notices. Accordingly, the final amendments will permit covered institutions to include additional information but will not permit omission of the prescribed information. In addition, the final amendments will require covered institutions to provide notice in a clear and conspicuous manner and by means designed to ensure that the customer can reasonably be expected to receive actual notice in writing.[198]

---

[198] *See* final rule 248.30(a)(4)(i); *see also* 17 CFR 248.9(a) (delivery requirements for privacy and opt out

Pursuant to 17 CFR 248.3, notices will therefore be required to be reasonably understandable and designed to call attention to the nature and significance of the information required to be provided in the notice.[199] To the extent that a covered institution includes information in the notice that is not required to be provided to customers under the final amendments or provides notice contemporaneously with other disclosures, the covered institution will still be required to ensure that the notice is designed to call attention to the important information required to be provided under the final amendments; the inclusion of any additional information in the notice may not prevent the required information from being presented in a clear and conspicuous manner. The requirement to provide notices in writing, further, will ensure that customers receive the information in a format appropriate for receiving important information, with accommodation for those customers who agree to receive the information electronically.[200] These requirements are designed to help ensure that customers are provided informative notifications and alerted to their importance.

Several commenters broadly supported the proposed notice contents and format requirements.[201] One commenter stated that the provision will lead to notices that contain important information in a clear and conspicuous manner, which will allow affected individuals to assess the risk of the incident paired with guidance on potential protective measures to take.[202]

---

notices) and 17 CFR 248.3(c)(1) (defining "clear and conspicuous").

199 *See* 17 CFR 248.3(c)(2) (providing examples explaining what is meant by the terms "reasonably understandable" and "designed to call attention" ).

200 This requirement to provide notice "in writing" could be satisfied either through paper or, for customers who agree to receive information electronically, though electronic means consistent with existing Commission guidance on electronic delivery of documents. *See* Use of Electronic Media by Broker Dealers, Transfer Agents, and Investment Advisers for Delivery of Information; Additional Examples Under the Securities Act of 1933, Securities Exchange Act of 1934, and Investment Company Act of 1940 [61 FR 24644 (May 15, 1996)]; Use of Electronic Media, [65 FR 25843 (May 4, 2000)].

201 *See*, *e.g.*, Better Markets Comment Letter, IAA Comment Letter 1; NASAA Comment Letter.

202 Better Markets Comment Letter (stating that the provision "avoids some common problems with the

Another commenter agreed with the proposed approach of requiring notices to contain certain information but not prescribing the specific format for the notices, asserting that this approach will "make it easier for covered institutions to fulfill all their notice obligations under federal and state laws with as few notice documents as possible (ideally through a single notice to all affected customers nationwide)."[203]

Conversely, a few commenters opposed certain aspects of the notice content and format requirements.[204] One commenter expressed concern related to the proposed requirement for covered institutions to include in the notice specific efforts they have taken to protect the sensitive customer information from further unauthorized access or use.[205] This commenter articulated that this information could be extremely useful to threat actors and not particularly useful to affected individuals.[206] Another commenter urged the Commission to remove the requirement for covered institutions to provide "the date of the incident, the estimated date of the incident, or the date range," asserting that this specific information is not required by the Banking Agencies' Incident Response Guidance and should not be included in an amended Regulation S-P.[207] In addition, two commenters suggested that the final amendments should provide more flexibility for covered institutions to determine the manner and method in which

---

content of many data breach notifications, such as confusing language, a lack of details, and insufficient attention to the practical steps customers should take in response.").

203 *See* NASAA Comment Letter (stating that "[b]eing prescriptive here could potentially create inconsistencies with current or future state notice laws, which in turn could cause covered institutions to feel compelled to deliver entirely duplicative notices to customers simply for reasons of form. Customers should not be burdened in this way, and the Reg. S-P Proposal rightly takes this into account.").

204 *See*, *e.g.*, CAI Comment Letter; ICI Comment Letter 1; IAA Comment Letter.

205 IAA Comment Letter 1.

206 *Id.* (further stating that in many cases "the adviser will have already remediated the vulnerability, making the information even less relevant to a client's decision.").

207 ICI Comment Letter 1.

they should be contacted by affected individuals inquiring about an incident.[208] Lastly, one commenter urged the Commission to consider whether it should require specific notice obligations at all, asserting that Federal notice would simply add another layer on top of existing State data breach notice requirements and would offer limited benefits to affected individuals.[209]

After considering comments, we are removing the specific requirement in the proposal that the notice "[d]escribe what has been done to protect the sensitive customer information from further unauthorized access or use." We agree that this information has the potential to advantage threat actors and does not provide actionable information for affected individuals. Accordingly, the provision has been removed from the final amendments, which should reduce the perceived risk of providing a roadmap for threat actors compared with the proposal. Covered institutions may, however, voluntarily disclose details related to the incident's remediation status.

The final amendments do not modify the proposed requirement for covered institutions to provide information about the date of the incident, as suggested by one commenter.[210] Providing this information to affected individuals, to the extent the information is reasonably possible to determine, can help affected individuals identify the point in time in which their sensitive customer information was compromised, thus providing critical details that affected individuals can use to take targeted protective measures (e.g., review account statements) to mitigate the potential harm that could result from the unauthorized access to or use of their sensitive customer

---

[208] CAI Comment Letter; SIFMA Comment Letter 2 (asserting that the rule should not require each of a telephone number, an email address, a postal address and a specific office contact, but rather should allow covered institutions to choose one or more of those contact options based on how the covered institution normally interacts with its customers).

[209] *See* CAI Comment Letter; *see also* NASDAQ Comment Letter (asserting that covered institutions "should be permitted to comply with various state and federal cybersecurity notification obligations with a single streamlined form.").

[210] ICI Comment Letter 1.

information. For this reason, we disagree with the commenter that stated firms should not be required to provide this information in their notice.

Similarly, the final amendments do not modify the requirement for notices to include the prescribed contact information sufficient to permit an affected individual to contact the covered institution to inquire about the incident. We understand that covered institutions communicate with their customers using many different methods and formats. However, providing a telephone number, an email address or equivalent method or means (e.g., an online submission form), a postal address, and the name of a specific office to contact, is designed to provide sufficient optionality for affected individuals, who may have differing preferences and aptitudes in their use of contact methods.[211] Nothing in this requirement, however, prevents a covered institution from choosing to provide additional contact methods.

Lastly, the final amendments do not prescribe a specific format for the notice to affected customers. We agree with the commenter that asserted that such flexibility will make it easier for covered institutions to provide notices that meet the requirements of the final amendments while also meeting the requirements of other notice obligations, such as certain state requirements, and thereby mitigates commenter concerns about the potential for more than one notice covering a given incident.

---

[211] In addition, the final rule's requirement to provide contact information sufficient to permit an affected individual to inquire about the incident does not preclude a covered institution from providing the contact information of a third-party service provider that has been engaged by the covered institution to provide specialized information or assistance about the unauthorized access or use of sensitive customer information on the covered institution's behalf. *See* CAI Comment Letter (asserting that it is current business practice for companies to hire vendors who provide specialized breach response call centers to handle consumer inquiries).

### 4. Service Providers

The final amendments require that each covered institution's incident response program include the establishment, maintenance, and enforcement of written policies and procedures reasonably designed to require oversight, including through due diligence on and monitoring, of service providers, including to ensure that the covered institution satisfies the customer notification requirements set forth in paragraph (a)(4) of the final amendments.[212] In a modification from the proposal, rather than requiring written policies and procedures requiring the covered institution to enter into a written contract with its service providers to take certain appropriate measures, the policies and procedures required by the final amendments must be reasonably designed to ensure service providers take appropriate measures to: (A) protect against unauthorized access to or use of customer information; and (B) provide notification to the covered institution as soon as possible, but no later than 72 hours after becoming aware of a breach in security has occurred resulting in unauthorized access to a customer information system maintained by the service provider.[213] In a modification from the proposal, upon receipt of such notification, a covered institution must initiate its incident response program pursuant to paragraph (a)(3) of this section.[214] The final amendments thus modify the proposal by removing the written contract requirement and shifting the notification deadline for the service provider's

---

212 *See* final rule 248.30(a)(5)(i).

213 *See id.* In the proposal, the covered institution's written contract with its service provider would have needed to require the service providers to take appropriate measures designed to protect against unauthorized access to or use of customer information, including notification to the covered institution as soon as possible, but no later than 48 hours after becoming aware of a breach in security resulting in unauthorized access to a customer information system maintained by the service provider to enable the covered institution to implement its response program. *See* proposed rule 248.30(b)(5)(i).

214 *See id*. As discussed further below, this modification responds to comments by incorporating into rule text the Commission's intention that covered institutions would "expeditiously" implement their incident response program following the receipt of such notification from a service provider, as discussed in the Proposing Release. *See infra* footnote 223 and accompanying discussion on clarifying modifications. *See also* Proposing Release at Section II.A.3.

notification of the covered institution from 48 to 72 hours, while retaining the notice trigger of the service provider "becoming aware of" a breach in security resulting in unauthorized access to a customer information system maintained by the service provider.[215]

However, the Commission is adopting as proposed final amendments that provide that a covered institution, as part of its incident response program, may enter into a written agreement with its service provider to notify affected individuals on the covered institution's behalf in accordance with paragraph (a)(4) of the final amendments.[216] In a modification from the proposal, the final amendments provide that even where a covered institution uses a service provider in accordance with paragraphs (a)(5)(i) and (ii) of the final amendments, the covered institution's obligation to ensure that affected individuals are notified in accordance with paragraph (a)(4) of the final amendments rests with the covered institution.[217]

Finally, the Commission is also defining a "service provider" at adoption to mean any person or entity that receives, maintains, processes, or otherwise is permitted access to customer information through its provision of services directly to a covered institution.[218] As discussed further below, this definition removes language from the proposed definition relating to third parties, but does so solely to make plain that the definition of a "service provider" can include affiliates of a covered institution.[219]

---

215 *See* final rule 248.30(a)(5)(i).

216 *See* final rule 248.30(a)(5)(ii).

217 *See* final rule 248.30(a)(5)(iii). As discussed further below, this modification is intended to clarify covered institutions' responsibilities under the final amendments by incorporating into rule text the Commission's intended scope, as discussed in the Proposing Release. *See* discussion on Delegation of Notice and Covered Institutions' Customer Notification Obligations *infra* Section II.A.4.c. and footnote 264, including accompanying discussion on clarifying modifications.

218 *See* final rule 248.30(d)(10).

219 As stated below, this modification from the proposal responds to comments by incorporating into rule text the Commission's intended scope of the "service provider" definition, as discussed in the Proposing Release. *See* discussion on the Service Provider definition *infra* footnote 271, including accompanying